

使用 Identity-Aware Proxy (IAP) 保護無伺服器應用程式

來源：<https://codelabs.developers.google.com/secure-serverless-application-with-identity-aware-proxy?hl=zh-tw>

步驟數：7

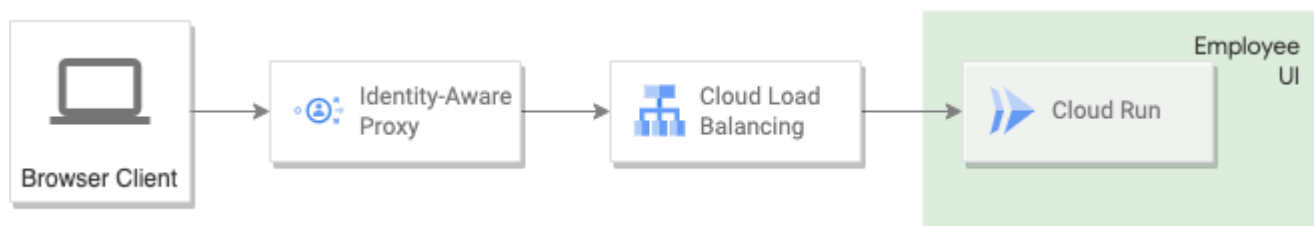
透過 Identity Aware Proxy 確保在 CloudRun 中運作的應用程式安全無虞，並要求使用者登入

目錄

1. [總覽](#)
2. [設定和需求](#)
3. [設定無伺服器網路端點群組 \(NEG\)](#)
4. [設定負載平衡器元件](#)
5. [在負載平衡器上啟用 Cloud Identity-Aware Proxy \(IAP\)](#)
6. [使用 IAP 限制存取權](#)
7. [恭喜！](#)

1. 總覽

在本實驗室中，您將部署員工入口網站，讓員工查看、更新及刪除 Cymbal Eats 應用程式的訂單。您將使用 [Identity-Aware Proxy \(IAP\)](#) 保護入口網站存取權，不必使用虛擬私人網路 (VPN)。IAP 可簡化零信任存取模型的導入作業，與 VPN 相比，可讓遠距工作者在地端部署和雲端環境中，以更短的時間存取應用程式，並透過單一控制點管理應用程式存取權。



什麼是 Identity-Aware Proxy ?

[Identity-Aware Proxy \(IAP\)](#) 是一項 Google Cloud 服務，可攔截傳送至應用程式的要求，使用 Google Identity 服務對發出請求的使用者進行身分驗證，並只允許已獲授權存取應用程式的使用者所傳送的要求。此外，這項功能還能修改要求標頭，加入已驗證使用者相關資訊。

學習目標

- 如何設定無伺服器網路端點群組 (NEG)
 - 如何設定負載平衡器
 - 如何啟用 IAP 來限制存取權
 - 如何使用 IAP 限制存取權
-

2. 設定和需求

自修實驗室環境設定

1. 登入 [Google Cloud 控制台](#)，然後建立新專案或重複使用現有專案。如果沒有 Gmail 或 Google Workspace 帳戶，請先[建立帳戶](#)。

The screenshot shows the Google Cloud Platform interface. At the top, there's a blue header with the Google Cloud Platform logo and a 'Select a project' button, which is circled in blue. Below this, the 'Select a project' section includes a search bar. The 'New Project' section follows, with a 'Project name' field containing 'my-kubernetes-codelab', also circled in blue. Below the name field, the 'Project ID' is displayed as 'my-kubernetes-codelab' with a note that it cannot be changed later. The 'Location' is set to 'No organization'. At the bottom, there are 'CREATE' and 'CANCEL' buttons.

- **專案名稱**是這個專案參與者的顯示名稱。這是 Google API 未使用的字元字串。你隨時可以更新該位置資訊。
- **專案 ID** 在所有 Google Cloud 專案中都是不重複的，而且設定後即無法變更。Cloud 控制台會自動產生不重複的字串，通常您不需要在意這個字串。在大多數程式碼研究室中，您需要參照專案 ID (通常會標示為 `PROJECT_ID`)。如果您不喜歡產生的 ID，可以產生另一個隨機 ID。你也可以嘗試使用自己的名稱，看看是否可用。完成這個步驟後就無法變更，且專案期間都會維持這個設定。
- 請注意，部分 API 會使用第三個值，也就是「專案編號」。如要進一步瞭解這三種值，請參閱[說明文件](#)。

注意：專案 ID 在全域中是專屬 ID，選定後就無法變更，且其他使用者無法使用。您是該 ID 的唯一使用者。即使刪除專案，該 ID 也無法再使用。

注意：如果您使用 Gmail 帳戶，可以將預設位置設為「沒有機構」。如果您使用 Google Workspace 帳戶，請選擇適合貴機構的位置。

2. 接著，您需要在 Cloud 控制台中[啟用帳單](#)，才能使用 Cloud 資源/API。完成本程式碼研究室的費用應該不高，甚至完全免費。如要關閉資源，避免產生本教學課程以外的費用，您可以刪除自己建立的資源，或刪除整個專案。Google

Cloud 新使用者可參加[價值\\$300 美元的免費試用計畫](#)。

環境設定

1. 建立專案和資源相關的環境變數



```
export PROJECT_ID=$(gcloud config get-value project)
export PROJECT_NUMBER=$(gcloud projects describe $PROJECT_ID --format='value(projectNumber)')
export REGION=us-east1
export ORDER_SERVICE_URL=order-service
export INVENTORY_SERVICE_URL=inventory-service
export MENU_SERVICE_URL=menu-service
```

2. 啟用 IAP 和 Cloud Resource Manager 服務 API

```
gcloud services enable \
  iap.googleapis.com \
  cloudresourcemanager.googleapis.com \
  cloudidentity.googleapis.com \
  compute.googleapis.com
```

3. 複製範例應用程式存放區並前往目錄

```
git clone https://github.com/GoogleCloudPlatform/cymbal-eats.git && cd cymbal-eats/employee-ui
```

4. 使用設定指令碼部署員工入口網站。等待指令碼完成，再進行下一個步驟

```
./setup.sh
```

輸出範例

```
...
Done.
Service [employee-ui-service] revision [employee-ui-service-00001-quw] has been
deployed and is serving 100 percent of traffic.
Service URL: https://employee-ui-service-gbtuuy5eda-uk.a.run.app
```

部署設定指令碼時，您可能會看到一些警告或錯誤。如果可以連上服務網址，請忽略並繼續下一個步驟

5. 按一下「服務網址」連結

Welcome! From here you can:

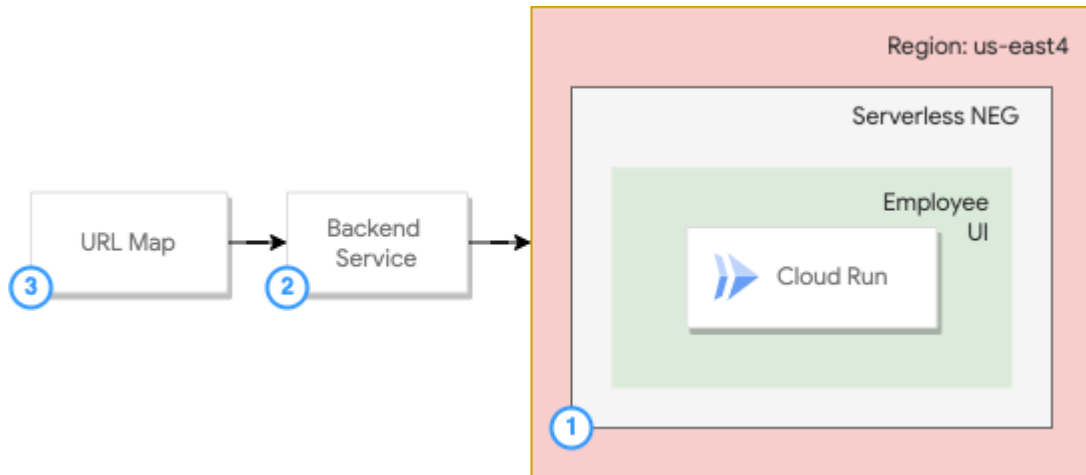
- [View and update pending orders](#)
- [Manage menu](#)

警告：由於未部署依附元件，連結將無法運作。

步驟 3 · 約 0 分鐘

3. 設定無伺服器網路端點群組 (NEG)

您將為員工 UI Cloud Run 服務建立無伺服器網路端點群組([無伺服器 NEG](#))。透過無伺服器 NEG，可搭配[外部 HTTP\(S\) 負載平衡](#)使用 [Google Cloud 無伺服器](#)應用程式。



1. 為員工 UI 服務建立網路端點群組。

```
gcloud compute network-endpoint-groups create employee-ui-iap-neg \
  --project $PROJECT_ID \
  --region=$REGION \
  --network-endpoint-type=serverless \
  --cloud-run-service=employee-ui-service
```

輸出範例

```
Created [https://www.googleapis.com/compute/v1/projects/cymbal-eats-18147-25762/regions/us-east1/networkEndpointGroups/employee-ui-iap-neg].
Created network endpoint group [employee-ui-iap-neg].
```

建立後端服務並新增無伺服器 NEG

後端服務可定義 Cloud Load Balancing 分配流量的方式。後端服務設定包含一組值，例如用於連線至後端的通訊協定、各種分配和工作階段設定、健康狀態檢查和逾時。這些設定可精細控管負載平衡器的行為。

2. 建立後端服務

```
gcloud compute backend-services create employee-ui-iap-backend \
  --global
```

輸出範例

```
Created [https://www.googleapis.com/compute/v1/projects/cymbal-eats-18147-25762/global/backendServices/employee-ui-iap-backend].  
NAME: employee-ui-iap-backend  
BACKENDS:  
PROTOCOL: HTTP
```

3. 將無伺服器 NEG 新增至後端服務並設為後端

```
gcloud compute backend-services add-backend employee-ui-iap-backend \  
  --global \  
  --network-endpoint-group=employee-ui-iap-neg \  
  --network-endpoint-group-region=$REGION
```

輸出範例

```
Updated [https://www.googleapis.com/compute/v1/projects/cymbal-eats-18147-25762/global/backendServices/employee-ui-iap-backend].
```

4. 建立網址對應，將傳入要求轉送至後端服務

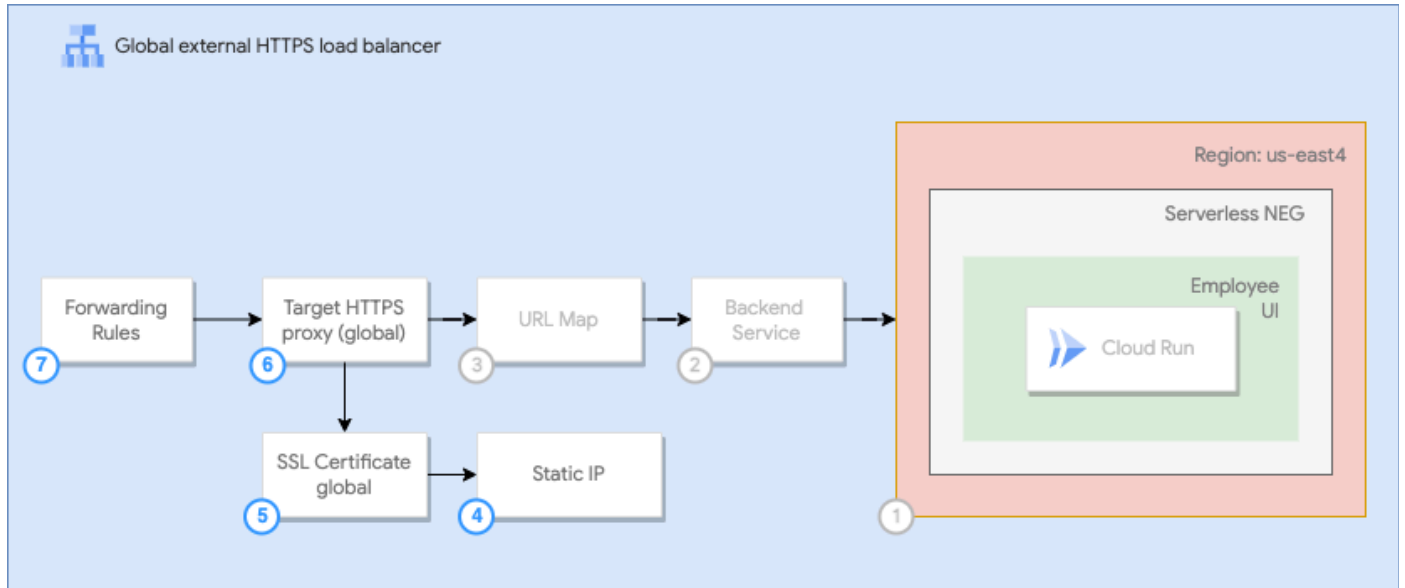
```
gcloud compute url-maps create employee-ui-iap-url-map \  
  --default-service employee-ui-iap-backend
```

```
Created [https://www.googleapis.com/compute/v1/projects/cymbal-eats-18147-25762/global/urlMaps/employee-ui-iap-url-map].  
NAME: employee-ui-iap-url-map  
DEFAULT_SERVICE: backendServices/employee-ui-iap-backend
```

步驟 4 · 約 0 分鐘

4. 設定負載平衡器元件

下圖顯示負載平衡器使用無伺服器 NEG 後端，將要求導向無伺服器 Cloud Run 服務。



保留靜態 IP 位址

1. 預留靜態 IPv4 位址並儲存網域

```
gcloud compute addresses create employee-ui-iap-ip \  
  --network-tier=PREMIUM \  
  --ip-version=IPV4 \  
  --global
```

輸出範例

```
Created [https://www.googleapis.com/compute/v1/projects/cymbal-eats-18147-25762/global/addresses/employee-ui-iap-ip].
```

這個範例需要執行這項步驟，一般情況下也建議這麼做。如果您的無伺服器應用程式使用自訂網域，就必須預留一個 IP 位址；使用 Google 代管的 SSL 憑證時同樣也需如此。若使用自訂網域，您需要更新 DNS 記錄，將網域指向這個 IP 位址。

2. 儲存 nip.io 網域

```
export DOMAIN=$(gcloud compute addresses list --filter employee-ui-iap-ip --  
format='value(ADDRESS)').nip.io
```

nip.io 用於測試。您可將靜態 IP 位址對應至主機名稱。在下一步建立 SSL 憑證時，nip.io 主機名稱會做為 `--domains` 標記。

建立 Google 代管的 SSL 憑證資源

3. 建立 Google 代管的 SSL 憑證資源

```
gcloud compute ssl-certificates create employee-ui-iap-cert \  
  --description=employee-ui-iap-cert \  
  --domains=$DOMAIN \  
  --global
```

輸出範例

```
Created [https://www.googleapis.com/compute/v1/projects/cymbal-eats-18147-  
25762/global/sslCertificates/employee-ui-iap-cert].  
NAME: employee-ui-iap-cert  
TYPE: MANAGED  
CREATION_TIMESTAMP: 2022-04-18T06:39:37.474-07:00  
EXPIRE_TIME:  
MANAGED_STATUS: PROVISIONING  
  
34.102.234.98.nip.io: PROVISIONING
```

此時，Google 代管憑證的狀態可能仍為「PROVISIONING」。Google Cloud 正在與憑證授權單位合作核發憑證。佈建 Google 代管的憑證最多可能需要 60 分鐘。

如要查看狀態，請使用下列指令：

```
gcloud compute ssl-certificates list --format='value(MANAGED_STATUS)'
```

在系統佈建 SSL 憑證期間，您可以繼續進行後續步驟。您必須先啟用 SSL 憑證，才能在本實驗室稍後驗證 IAP 設定。

建立目標 HTTPS Proxy

4. 建立目標 HTTPS Proxy，將要求轉送至網址對應

```
gcloud compute target-https-proxies create employee-ui-iap-http-proxy \  
  --ssl-certificates employee-ui-iap-cert \  
  --url-map employee-ui-iap-url-map
```

輸出範例

```
Created [https://www.googleapis.com/compute/v1/projects/cymbal-eats-18147-25762/global/targetHttpsProxies/employee-ui-iap-http-proxy].  
NAME: employee-ui-iap-http-proxy  
SSL_CERTIFICATES: employee-ui-iap-cert  
URL_MAP: employee-ui-iap-url-map  
CERTIFICATE_MAP:
```

設定轉送規則

5. 建立轉送規則，將傳入要求轉送至 Proxy

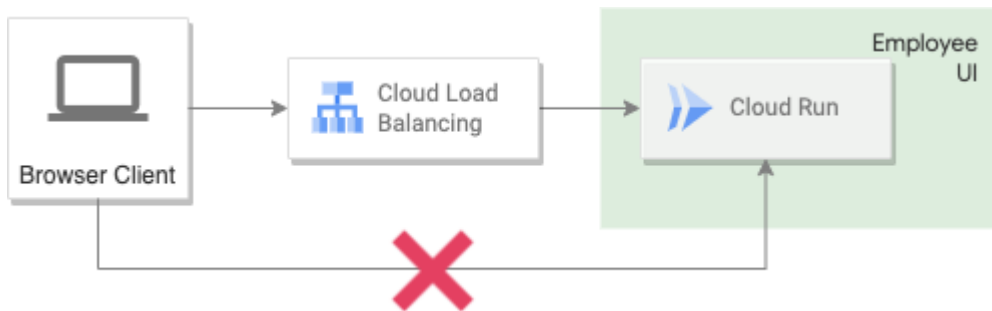
```
gcloud compute forwarding-rules create employee-ui-iap-forwarding-rule \  
  --load-balancing-scheme=EXTERNAL \  
  --network-tier=PREMIUM \  
  --address=employee-ui-iap-ip \  
  --global \  
  --ports=443 \  
  --target-https-proxy employee-ui-iap-http-proxy
```

輸出範例

```
Created [https://www.googleapis.com/compute/v1/projects/cymbal-eats-18147-25762/global/forwardingRules/employee-ui-iap-forwarding-rule].
```

限制 Cloud Run 服務的輸入流量

限制 Ingress 流量，只接受內部要求和透過 HTTP(S) 負載平衡傳送的要求。



1. 更新服務，只允許來自內部要求和透過 HTTP(S) 負載平衡器的 Ingress 流量

```
gcloud run services update employee-ui-service \  
  --ingress internal-and-cloud-load-balancing \  
  --region $REGION
```

輸出範例

OK Deploying... Done.

OK Creating Revision...

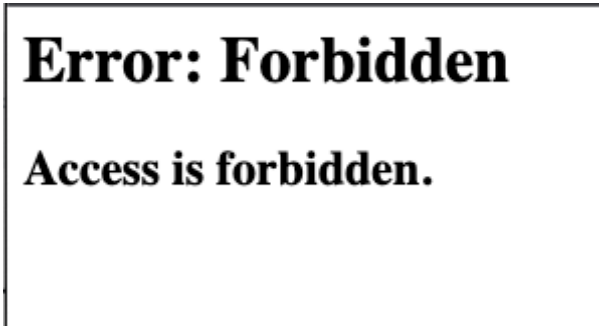
OK Routing traffic...

Done.

Service [employee-ui-service] revision [employee-ui-service-00001-quw] has been deployed and is serving 100 percent of traffic.

Service URL: <https://employee-ui-service-gbtuuy5eda-uk.a.run.app>

2. 按一下「服務網址」連結



Error: Forbidden
Access is forbidden.

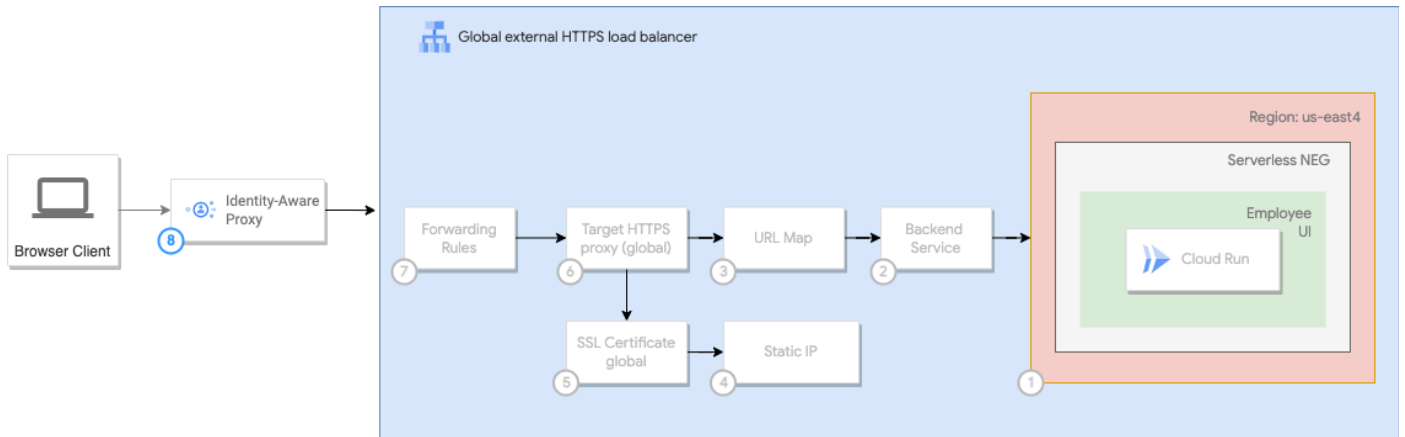
A screenshot of a web browser displaying a 403 Forbidden error. The text "Error: Forbidden" is in a large, bold, black font, and "Access is forbidden." is in a slightly smaller, bold, black font below it. The background is white, and there is a thin black border around the text area.

現在存取 Cloud Run 服務網址時，系統會顯示存取遭拒。

步驟 5 · 約 0 分鐘

5. 在負載平衡器上啟用 Cloud Identity-Aware Proxy (IAP)

透過 HTTPS 存取的應用程式可經由 IAP 建立中央授權層。因此，您可以使用應用程式層級的存取控管模型，而非網路層級的防火牆。



設定 OAuth 同意畫面

品牌是 OAuth 同意畫面，內含使用者的品牌宣傳資訊。品牌可能僅限內部或公開使用者。內部品牌可讓與專案屬於同一 Google Workspace 機構的成員存取 OAuth 流程。公開品牌可讓任何能存取網際網路的使用者，都能存取 OAuth 流程。

1. 建立品牌

```
export USER_EMAIL=$(gcloud config list account --format "value(core.account)")

gcloud alpha iap oauth-brands create \
  --application_title="Cymbal Eats" \
  --support_email=$USER_EMAIL
```

輸出範例

```
Created [462858740426].
applicationTitle: Cymbal Eats
name: projects/462858740426/brands/462858740426
orgInternalOnly: true
```

建立 IAP OAuth 用戶端

1. 使用上一個步驟中的品牌名稱建立用戶端

```
gcloud alpha iap oauth-clients create \
  projects/$PROJECT_ID/brands/$PROJECT_NUMBER \
  --display_name=cymbal-eats-employee-ui
```

輸出範例

```
Created [462858740426-tkpv8n03opijg7erd3s9ccued2pfllsd.apps.googleusercontent.com].
displayName: cymbal-eats-employee-ui
name:
projects/462858740426/brands/462858740426/identityAwareProxyClients/462858740426-
tkpv8n03opijg7erd3s9ccued2pfllsd.apps.googleusercontent.com
secret: [secret-removed]
```

2. 儲存用戶端名稱、ID 和密鑰

```
export CLIENT_NAME=$(gcloud alpha iap oauth-clients list \
  projects/$PROJECT_NUMBER/brands/$PROJECT_NUMBER --format='value(name)' \
  --filter="displayName:cymbal-eats-employee-ui")

export CLIENT_ID=${CLIENT_NAME##*/}

export CLIENT_SECRET=$(gcloud alpha iap oauth-clients describe $CLIENT_NAME --
  format='value(secret)')
```

2. 在 Cloud 控制台中，從下拉式專案選單選取專案

3. 前往 Cloud 控制台的「OAuth 同意畫面」

API	APIs & Services	OAuth consent screen
	Enabled APIs & services	Cymbal Eats  EDIT APP User type Internal  MAKE EXTERNAL OAuth rate limits Your token grant rate  Token grant rates limit how quickly your application can get new users. Your current per day token grant rate limit is 70,000 grants per day. The per day token grant rate resets every day. Raise daily token limit 5 minutes ☒ 1 day 70,001
	Library	
	Credentials	
	OAuth consent screen	
	Domain verification	
	Page usage agreements	

4. 按一下「使用者類型」下方的「設為外部」

5. 將「發布狀態」選為「測試」

Make external?

Please choose the publishing status of your external app.

Publishing status

☒ **Testing** ?

Apps still in development. Your app will only be available to users you add to the list of test users.

☐ **In production** ?

Apps ready for the public. Your app will be available to anyone with a Google Account. You do not need to submit your app for verification. If you change your app's configuration in the future, like adding more than 10 domains, uploading a logo, or requesting sensitive or restricted scopes, you will need to [submit for verification](#).

CANCEL CONFIRM

6. 按一下「確認」

6. 使用 IAP 限制存取權

使用 IAP 限制後端服務的存取權，然後確認應用程式無法存取。

1. 在後端服務上啟用 IAP

```
gcloud iap web enable --resource-type=backend-services \  
  --oauth2-client-id=$CLIENT_ID \  
  --oauth2-client-secret=$CLIENT_SECRET \  
  --service=employee-ui-iap-backend
```

驗證 IAP 設定

1. 確認 SSL 憑證為「ACTIVE」狀態

```
gcloud compute ssl-certificates list --format='value(MANAGED_STATUS)'
```

注意：請等待狀態顯示為「ACTIVE」再繼續操作。這項程序最多可能需要 60 分鐘的時間。

2. 取得服務網址

```
echo https://$DOMAIN
```

輸出範例

```
https://34.102.234.98.nip.io
```

3. 按一下服務網址，開啟員工入口網站。

注意：變更需要 5 到 7 分鐘才會生效。如果系統顯示登入提示，請稍後再試。

 Sign in with Google

Sign in

to continue to iap.googleapis.com

Email or phone

[Forgot email?](#)

To continue, Google will share your name, email address, language preference, and profile picture with iap.googleapis.com.

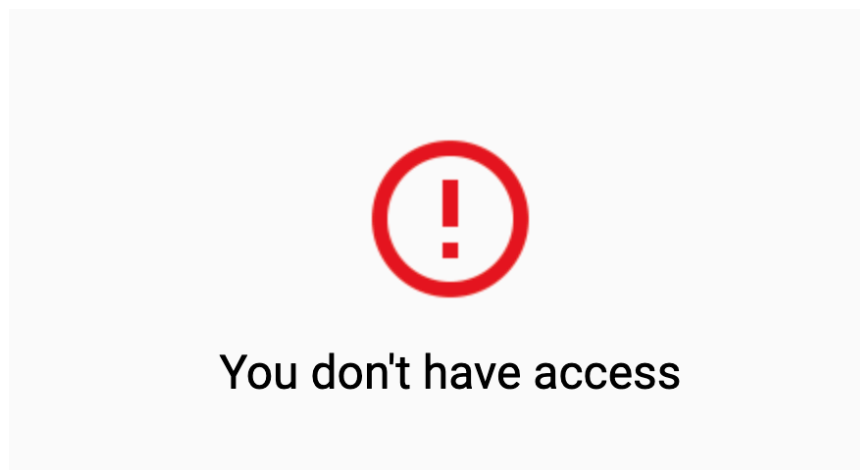
[Create account](#)

Next

English (United States) ▾

HelpPrivacyTerms

4. 使用實驗室憑證登入。



5. 關閉瀏覽器

授予使用者員工入口網站存取權

1. 為上一個步驟中建立的使用者新增 `'roles/iap.httpsResourceAccessor'` 角色的 IAM 政策繫結

```
gcloud iap web add-iam-policy-binding \  
  --resource-type=backend-services \  
  --service=employee-ui-iap-backend \  
  --member=user:$USER_EMAIL \  
  --role='roles/iap.httpsResourceAccessor'
```

輸出範例

```
Updated IAM policy for backend service  
[projects/462858740426/iap_web/compute/services/employee-ui-iap-backend].
```

`-member` 旗標的選項可以是使用者、群組、服務帳戶或網域。建議使用群組。

測試服務存取權

確認已授予員工入口網站存取權

1. 取得服務網址

```
echo https://$DOMAIN
```

輸出範例

```
https://34.102.234.98.nip.io
```

注意：更新後端的 IAM 政策可能需要幾分鐘才能完成同步。如果無法存取員工入口網站，請重新整理頁面。

2. 按一下服務網址，開啟員工入口網站。

≡ Cymbal Eats

Welcome! From here you can:

- [View and update pending orders](#)
- [Manage menu](#)

警告：由於未部署依附元件，連結將無法運作。

你現在應該可以存取員工入口網站。

(選用) 部署所有依附元件，部署這些微服務可能需要約 20 分鐘。

```
unset ORDER_SERVICE_URL
unset INVENTORY_SERVICE_URL
unset MENU_SERVICE_URL

cd ~/cymbal-eats

./setup.sh
./get-site-urls.sh
```

注意：這組指令會部署員工 UI 入口網站功能所需的所有服務。

步驟 7 · 約 0 分鐘

7. 恭喜！

恭喜，您已完成本程式碼研究室！

後續步驟：

探索其他 Cymbal Eats 程式碼研究室：

- [使用 Eventarc 觸發 Cloud Workflows](#)
- [透過 Cloud Storage 觸發事件處理作業](#)
- [從 Cloud Run 連線至私人 Cloud SQL](#)
- [從 Cloud Run 連線至全代管資料庫](#)
- [使用 Cloud Scheduler 觸發 Cloud Run 工作](#)
- [安全部署至 Cloud Run](#)
- [保護 Cloud Run 輸入流量](#)
- [從 GKE Autopilot 連線至私人 AlloyDB](#)

清除所用資源

如要避免系統向您的 Google Cloud 帳戶收取本教學課程所用資源的費用，請刪除含有相關資源的專案，或者保留專案但刪除個別資源。

刪除專案

如要避免付費，最簡單的方法就是刪除您為了本教學課程所建立的專案。
